

Information Security Management System (ISMS) Roles & Responsibilities

ISMS Governance Policy | Version 1.0 | Approved

Document Owner	Information Security / GRC
Status	Approved 2026-09-23
Review Frequency	At least annually and upon significant change
Framework Alignment	ISO/IEC 27001:2022
Classification	Internal Use

1. Purpose

This document defines the roles, responsibilities, and authorities required to establish, operate, maintain, and continually improve the Axiom AI Technologies Information Security Management System (ISMS).

Clearly defined responsibilities help ensure that information security risks, controls, policies, incidents, compliance requirements, and improvement activities have appropriate ownership.

The responsibilities described in this document apply to personnel and functions whose activities may affect information security within the ISMS scope.

2. Responsibility Principles

Axiom AI assigns information security responsibilities according to the following principles:

- Information security is a shared organizational responsibility.
- Management provides leadership, direction, and resources for the ISMS.
- Information security and GRC personnel coordinate and monitor the ISMS.
- Business and technical owners are responsible for risks and controls within their areas of responsibility.
- Personnel are responsible for complying with applicable security policies and reporting security concerns.
- Responsibilities shall be reviewed when organizational roles or the ISMS change.
- Conflicts of responsibility shall be identified and managed where practical.

3. ISMS Governance Structure

The ISMS operates through coordinated responsibilities across management, information security, engineering, operations, human resources, procurement, and business functions.

The general governance structure is:

Executive Management



ISMS Owner / Information Security Leadership



GRC / Compliance Coordination



Business, Engineering, IT, and Functional Owners



Employees and Contractors

Third-party providers are managed through the organization's supplier and third-party security processes.

4. Executive Management

Responsibilities

Executive Management provides leadership and oversight for the organization's information security program.

Responsibilities include:

- Approving the Information Security Policy.
- Providing appropriate resources for operation and improvement of the ISMS.
- Establishing organizational expectations for information security.
- Reviewing significant information security risks.
- Reviewing significant security incidents and business-impacting events.
- Supporting risk treatment decisions requiring executive involvement.
- Reviewing ISMS performance.
- Participating in management reviews.
- Supporting continual improvement of the ISMS.
- Ensuring that information security objectives remain aligned with business objectives.

Authority

Executive Management has authority to:

- Approve significant risk treatment decisions.
- Accept information security risks within established organizational authority.
- Approve major changes to the ISMS.
- Allocate resources required to address significant information security risks.

5. ISMS Owner / Information Security Manager

The ISMS Owner is responsible for coordinating the overall operation and maintenance of the Information Security Management System.

Responsibilities

- Maintain the ISMS framework.
- Coordinate development and maintenance of ISMS documentation.
- Coordinate information security risk management activities.
- Monitor progress against ISMS objectives.
- Coordinate control assessments.
- Coordinate corrective and remediation activities.
- Maintain awareness of applicable information security requirements.
- Coordinate internal ISMS reviews and assessments.
- Support management reviews.
- Monitor significant changes affecting the ISMS.
- Coordinate continual improvement activities.
- Ensure that the Statement of Applicability remains current.
- Coordinate preparation for external assessments or certification activities where applicable.

Authority

The ISMS Owner may:

- Request information necessary to operate the ISMS.
- Escalate significant security risks to management.
- Require corrective actions to address identified control deficiencies.
- Recommend changes to policies, controls, and ISMS processes.

6. GRC / Compliance Function

The GRC function supports the governance, risk, and compliance activities associated with the ISMS.

Responsibilities

- Maintain the risk register.
- Support risk assessments.
- Maintain risk treatment documentation.
- Coordinate control assessments.
- Track security findings and remediation activities.
- Maintain compliance documentation.
- Support the Statement of Applicability.
- Monitor applicable legal, regulatory, contractual, and customer requirements.
- Support internal audits and assessments.
- Maintain evidence supporting ISMS activities.
- Prepare reporting for management review.
- Track corrective actions and improvement opportunities.

Authority

The GRC function may:

- Request evidence from control owners.
- Escalate overdue remediation activities.
- Recommend risk treatment actions.
- Identify control or compliance gaps requiring management attention.

7. Engineering and IT

Engineering and IT are responsible for implementing and maintaining technical security controls within their areas of responsibility.

Responsibilities

- Implement approved technical security controls.
- Maintain secure system configurations.
- Manage system access and technical privileges.
- Support vulnerability identification and remediation.
- Maintain appropriate logging and monitoring.

- Support incident detection and response.
- Support backup and recovery activities.
- Implement approved security changes.
- Maintain system and technology documentation.
- Support security assessments and audits.
- Address technical remediation activities.
- Protect credentials, secrets, and other sensitive technical information.

Authority

Engineering and IT may:

- Implement approved technical security controls.
- Restrict or suspend access when required to protect systems.
- Escalate technical security risks.
- Recommend technical security improvements.

8. System and Asset Owners

System and Asset Owners are responsible for information systems and assets assigned to their area of responsibility.

Responsibilities

- Maintain awareness of assets under their ownership.
- Ensure appropriate security requirements are identified.
- Participate in risk assessments.
- Review access requirements.
- Support security control implementation.
- Ensure identified security issues are addressed.
- Support business continuity and recovery planning.
- Provide information required for audits and assessments.
- Notify the ISMS Owner of significant changes affecting security.

Authority

System and Asset Owners may:

- Approve or deny access based on business requirements and established authorization procedures.
- Recommend security requirements for systems and assets.
- Escalate risks associated with assets under their ownership.

9. Human Resources

Human Resources supports information security requirements associated with personnel throughout the employment lifecycle.

Responsibilities

- Support security requirements during onboarding.
- Maintain appropriate personnel records.
- Support security awareness and training requirements.
- Notify relevant functions of personnel changes requiring access updates.
- Support offboarding activities.
- Support acknowledgement of applicable policies.
- Coordinate with Information Security regarding personnel-related security requirements.

Authority

Human Resources may:

- Require completion of applicable personnel processes.
- Coordinate personnel actions affecting information security responsibilities.

10. Procurement and Vendor Management

Procurement and Vendor Management are responsible for coordinating third-party security requirements with relevant stakeholders.

Responsibilities

- Identify vendors requiring security assessment.
- Coordinate third-party security due diligence.
- Maintain vendor information relevant to security risk.
- Support security requirements within contracts and agreements.
- Coordinate periodic reassessment of higher-risk vendors.
- Track unresolved third-party security findings.
- Escalate significant vendor risks.
- Coordinate with Information Security before onboarding higher-risk providers where required.

11. Incident Response Responsibilities

Personnel responsible for information security incident management shall coordinate the identification, assessment, containment, response, recovery, and review of security incidents.

Responsibilities include:

- Receiving and assessing reported security events.
- Determining whether an event constitutes an information security incident.
- Coordinating incident response activities.
- Escalating significant incidents to appropriate management.
- Coordinating technical investigation and remediation.
- Maintaining appropriate incident records.
- Coordinating internal communications.
- Determining whether external notification requirements may apply.
- Conducting post-incident reviews.
- Tracking corrective actions and lessons learned.

Specific incident response responsibilities shall be defined within the Incident Response Policy and supporting procedures.

12. Risk Owners

Risk Owners are responsible for risks assigned to them through the organization's risk management process.

Responsibilities

- Understand assigned risks.
- Review risk assessments.
- Participate in risk treatment decisions.
- Approve or recommend appropriate treatment actions.
- Monitor risk treatment progress.
- Escalate risks that exceed established acceptance thresholds.
- Support periodic risk reviews.

Risk Owners may be business, technical, operational, or management personnel depending on the nature of the identified risk.

13. Control Owners

Control Owners are responsible for the implementation and ongoing operation of specific security controls.

Responsibilities

- Understand assigned control requirements.
- Implement or coordinate control activities.
- Maintain supporting evidence.
- Monitor control performance.
- Participate in control assessments.
- Address identified control deficiencies.
- Complete assigned remediation activities.
- Report significant control issues to the appropriate management or GRC function.

14. Employees and Contractors

All employees and contractors are responsible for complying with applicable information security requirements.

Responsibilities

- Follow applicable information security policies.
- Protect company information and assets.
- Use systems and services appropriately.
- Protect authentication credentials.
- Complete required security awareness training.
- Report suspected security incidents promptly.
- Report suspected vulnerabilities or security weaknesses.
- Follow access control requirements.
- Protect confidential and sensitive information.
- Participate in security activities applicable to their roles.

Employees and contractors shall not intentionally bypass established security controls or use company systems in a manner that creates unnecessary information security risk.

15. Third-Party Service Providers

Third-party service providers are responsible for complying with applicable contractual and security requirements established by Axiom AI.

Responsibilities may include:

- Protecting Axiom AI information entrusted to the provider.
- Meeting applicable contractual security requirements.
- Supporting security assessments where required.
- Reporting security incidents affecting Axiom AI information or services.
- Cooperating with security investigations where contractually required.
- Maintaining appropriate security controls within the provider's area of responsibility.

Third-party responsibilities shall be defined through applicable contracts, agreements, security requirements, and vendor management processes.

16. Responsibility Matrix

Activity	Executive Management	ISMS Owner / InfoSec	GRC	Engineering / IT	HR	Procurement	Risk Owner	Control Owner	Employees / Contractors
ISMS Governance	A	R	C	C	C	C	C	C	I
Information Security Policy	A	R	C	C	C	I	I	C	I
Risk Management	A	R	R	C	I	C	A/R	C	I
Risk Treatment	A	C	R	C	I	C	A/R	R	I
Control Assessment	I	A	R	C	C	C	C	R	I
Access Management	I	A	C	R	C	I	C	R	R
Incident Response	A	R	C	R	C	C	C	C	R
Vulnerability Management	I	A	C	R	I	I	C	R	I
Third-Party Security	A	C	R	C	I	R	C	C	I
Security Awareness	I	A	C	C	R	I	I	I	R
Business Continuity	A	R	C	R	C	C	C	C	I
ISMS Objectives	A	R	C	C	C	C	I	I	I
Management Review	A/R	R	C	C	C	C	C	C	I
Continual Improvement	A	R	R	C	C	C	C	R	I

Legend:

- **R — Responsible:** Performs or coordinates the activity.
- **A — Accountable:** Ultimately accountable for the outcome or decision.
- **C — Consulted:** Provides relevant input.
- **I — Informed:** Kept informed of relevant activities or outcomes.

17. Segregation of Duties

Axiom AI shall maintain appropriate segregation of duties where practical to reduce the risk of unauthorized activity, conflicts of interest, or inappropriate control over critical processes.

Examples may include:

- Separation between requesting and approving privileged access.
- Separation between security control operation and independent assessment where practical.
- Separation between risk identification and risk acceptance authority.
- Independent review of significant security findings where appropriate.
- Management approval for significant risk acceptance decisions.

Where complete segregation is not practical due to organizational size or resource limitations, compensating controls shall be considered and documented where appropriate.

18. Escalation

Information security matters shall be escalated according to their severity, business impact, risk, and applicable organizational procedures.

Escalation may be required for:

- High or critical information security risks.
- Significant security incidents.
- Material control failures.
- Significant third-party security issues.
- Major compliance or contractual concerns.
- Security issues affecting critical business operations.
- Risks that exceed established acceptance thresholds.

The ISMS Owner, relevant Risk Owner, and Executive Management shall be involved according to the significance of the issue.

19. Review and Maintenance

This document shall be reviewed at least annually and whenever significant changes occur to:

- Organizational structure
- Business operations
- Technology environment
- ISMS scope
- Security responsibilities
- Regulatory or contractual requirements
- Information security risks

Changes to roles and responsibilities shall be documented and communicated to affected personnel.

20. Approval

This document shall be approved by appropriate organizational management before being considered an active component of the Axiom AI ISMS.

Approval shall confirm that the responsibilities defined within this document are appropriate for the organization's structure and operating environment.